

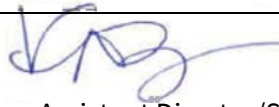


DAS Policy

Identity Proofing

No:
2100-20

Effective:
April 29, 2025

Approval: 
Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide guidance for the use of **Identity Proofing** for **Non-Organizational Users** associated with the state's **Identity Management System**. The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes all Non-Organizational User accounts in the state's Identity Management System. This policy represents the minimum acceptable criteria governing the automatic creation of all Non-Organizational User accounts.

III. Policy

The Ohio Department of Administrative Services (DAS) Office of Information Technology (OIT) shall provide Identity Proofing services, which meet the requirements outlined in this policy.

A. **Identity Proofing Non-Organizational User Accounts:** Each application owner shall determine Identity Proofing requirements based on the risk of harm associated with the transactions processed in their respective application and based on the results of their data classification. Potential harms include identity theft, fraud, unauthorized disclosure of information, and account takeover.

1. Low Risk of Harm Transactions: Identity Proofing of Non-Organizational Users is not required when there is little or no risk of harm to the state, users, or others. For example, giving the state funds or information is typically low risk.

2. Moderate or High Risk of Harm Transactions: Identity Proofing of Non-Organizational Users is required when there is a moderate or high risk of harm to the state, users, or others. For example, transactions containing financial or **Confidential Data**.
 3. Migration of Existing Users: Non-Organizational Users of an application may be migrated into the system and may not require additional Identity Proofing to access that application. However, these users may require Identity Proofing to access additional applications, as determined by each application owner.
 4. **Authorized Business Representatives**: Businesses registered to use the identity system shall be required to complete business Identity Proofing.
 - a) During this process, an Authorized Business Representative is identified and shall be required to complete Identity Proofing. This person will have the ability to assign and approve elevated privileges, and to create additional **Privileged Users** and general users within their business accounts.
 - b) Any additional users associated with a business account shall also be required to complete Identity Proofing before becoming Privileged Users.
- B. **Identity Re-Proofing**: Citizens, businesses, and Authorized Business Representatives shall be required to undergo identity re-proofing under the following circumstances:
1. Citizen Re-Proofing: Citizens shall be required to repeat Identity Proofing when their core identity information changes, as it relates to the information used to provide assurance of a citizen's identity, such as:
 - a) First Name
 - b) Last Name
 - c) Date of Birth
 - d) Social Security Number or similar National Identification Number
 2. Business Re-Proofing: Businesses shall be required to repeat Identity Proofing when there is a change to their core business identifiers, as it relates to the information used to provide assurance of a business' identity. For example, changes to the following:
 - a) Federal Employer Identification Number (FEIN)
 - b) Business name
 - c) Business address
 3. Authorized Business Representatives Re-Proofing: Authorized Business Representatives shall be required to repeat Identity Proofing when there is a change to their core identity information, as it relates to information used to provide assurance of a business representative's identity, such as:
 - a) First Name
 - b) Last Name
 - c) Date of Birth

- d) SSN or similar National Identification Number
 - 4. Identity Re-Proofing for Identity Theft: Identity re-proofing shall be required when a citizen or business representative's identity is flagged as a victim of identity theft.
 - 5. Business/Application Owner Identity Re-Proofing Requirements: Business/application owners are authorized to require Identity Proofing frequencies or conditions for Identity Proofing that are more stringent than the requirements of this policy. These decisions shall be based upon the information contained in the application or the sensitivity of the business transactions that are conducted through the use of the application.
- C. **Identity Validations:** When high-risk financial transactions are involved, a business owner requests validation based on their data classification results, or if a user wishes to opt in to additional security measures. The exception process shall be followed whenever Identity Validations are used in place of Identity Proofing.
- Below are examples of Identity Validations which can be used to ensure a registered user is the person authorized to complete a specific transaction.
- 1. Re-authentication: A re-authentication process shall be available, which can be employed to complete sensitive transactions.
 - 2. **Two-Step Authentication:** A Two-Step Authentication process shall be available, which can be employed to complete sensitive transactions. Examples of Two-Step Authentication include:
 - a) Sending an authentication code to a mobile phone number on file.
 - b) Requiring the end-user to answer security questions on file.
- D. **Notification Messages:** Notification messages, such as postal letters, emails, or notifications at login, shall be available to inform a user when changes are made to their state profile. This would include offering a means of redress in the event that their state identity was compromised and used without their knowledge.
- E. **Identity Proofing Process:** Identity Proofing shall be completed using an automated process, a manual process, or a combination of automated and manual processes.

Alternative manual Identity Proofing processes shall be established that meet a burden of proof similar to that of an automated Identity Proofing process. In the event of a failure of an automated Identity Proofing process (e.g., an issue with the information associated with the individual completing the process), the application owner has discretion to approve application access without completing an Identity Proofing process. This approval does not

transfer to other state application owners but shall be documented in the Identity Management System.

- F. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Authorized Business Representative. For the purposes of this policy, an individual who is appointed by a business to initiate, modify or complete transactions with the state on behalf of the business. This designation provides the person(s) with the ability to assign and approve elevated privileges, and to create additional Privileged Users and general users within their business accounts that also have the ability to initiate, modify or complete transactions with the State of Ohio.
- B. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- C. Identity Management System. An Identity Management System is comprised of one or more systems or applications that manage the identity verification, validation, and issuance process.¹
- D. Identity Proofing. The process of providing sufficient information (e.g., identity history, credentials, documents) to establish an identity.²
- E. Identity Validation. Tests enabling an information system to authenticate users or resources.³
- F. Non-Organizational User. A user who is not an **Organizational User**, which for the purposes of this policy includes public users.
- G. Organizational User. An Organizational User is anyone who is an employee of the state or is otherwise authorized to work on behalf of the State, and who has a need to access State of

¹ “FIPS PUB 201-2, Personal Identity Verification (PIV) of Federal Employees and Contractors.” Federal Information Processing Standards Publication (FIPS) August 2013. <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.201-2.pdf>>.

² *Ibid.*

³ “CNSS Instruction No. 4009, National Information Assurance (IA) Glossary,” Committee on National Security Systems, April 2010 <<https://www.hsdl.org/?abstract&did=7447>>.

Ohio IT systems and has secured agency authorization for such access. The Organizational User identifier will help to distinguish the individual during the authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User identifier category may also include university and federal government resources.

- H. Privileged User. A user that is authorized (and, therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform.⁴
- I. Two-Step Authentication. Requires the user to provide an additional layer of information to authenticate to a system. In addition to a password (something users know), the user is prompted to provide an additional piece of security information (something they have). For example, sending an authentication code to a mobile phone number on file or requiring the user to answer security questions on file.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
NIST Special Publication (SP) 800-63-3, Digital Identity Guidelines	https://csrc.nist.gov/publications/sp
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-01 Password Policy	https://das.ohio.gov/technology-and-strategy/policies
DAS-ITS-2100-01-A, Password Standard for Organizational Users	https://das.ohio.gov/technology-and-strategy/policies

⁴ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

Document Name	Location
DAS-ITS-2100-01-B, Password Standard for Non-Organizational Users	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/21/2018	Revised the policy to clarify information system backup requirements.
06/10/2020	Updated the policy template.
09/30/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.